

5-Step Security Risk Assessment Process

What is Security Risk Assessment?

A security risk assessment identifies security risks in a computing system, evaluates and prioritizes those risks, and suggests security controls that can mitigate the risks. Another aspect of security risk assessments is [vulnerability assessment](#)—the process of identifying and remediating vulnerabilities across the organization.

Performing a risk assessment can provide organizations with a complete view of the exploitability of their infrastructure and application portfolio. It helps administrators make informed decisions about resource allocation, tools, and implementation of security controls. Therefore, conducting an assessment is an essential part of an organization's risk management process.

What is the Difference Between Risk Management and a Security Risk Assessment?

Security risk assessments provide comprehensive evaluations of a company, department, or specific IT project. It aims to locate security gaps and weaknesses before threat actors exploit them by reviewing and testing systems and people. Identified security issues are ranked according to the risk they pose.

A security risk assessment report identifies properly secured systems and those with issues, providing specific technical recommendations, such as firewall configuration and network scanning.

Risk management is the ongoing effort to identify and fix all the known issues. It involves monthly or weekly identification of risks and issues. Each risk is ranked, and stakeholders discuss how to ensure security continues to hold. The goal is to continually improve the organization's security posture and eliminate risks as they emerge.

Who Should Perform a Cyber Risk Assessment?

Organizations can set up a dedicated in-house team for risk assessments or contract third parties. It requires organizational transparency, typically provided by internal teams. However, not all organizations can afford or staff an in-house team.

An in-house team typically includes an IT team with a thorough understanding of the organization's digital and network infrastructure and executives versed in information flows and relevant proprietary organizational knowledge. Organizations with no skilled personnel can outsource risk assessment to a third party.

Systems Included in a Security Risk Assessment

A security risk assessment typically includes one or more of the following:

- **Facility analysis**—evaluates physical security of the organization's buildings. For example, checking whether the organization has reliable power backup for emergencies, and how locks, cameras, and alarm systems prevent physical intrusion.
- **Server analysis**—evaluates security of servers and other mission critical computing systems for issues like server redundancy, malware protection, authentication, and authorization.
- **Network analysis**—evaluates internal and external networks, switches, routers, and other network equipment, network segmentation, firewalls, and wireless networks.
- **Data security analysis**—evaluates how the organization stores sensitive data, how it is classified, how it is encrypted, and access is granted to that data.
- **Company policy**—evaluating security procedures, IT policies including Bring Your Own Device (BYOD) policies, disaster recovery plans, business continuity plans, and risk management policies.
- **Third-party security analysis**—evaluating all of the above for each third party that has access to the company's systems.

5-Step Risk Assessment Process

1. Determine the Scope of the Risk Assessment

The first step is determining the scope of the risk assessment. The scope can encompass an entire organization or specific business units, locations, or certain components like payment processing.

Once you determine the scope, you need to get all relevant stakeholders on board, particularly those whose activities fall within the scope of the assessment. Their input is essential to identifying the relevant processes and assets, locating risks, assessing impacts, and defining risk tolerance levels.

All stakeholders involved in the assessment process should learn the relevant terminology, including likelihood and impact. It helps standardize risk and ensure accurate communication. Additionally, organizations should review frameworks like NIST SP 800-37 and standards like ISO/IEC 27001 for guidance and clarity on effective security controls.

2. Threat and Vulnerability Identification

A threat is any event that can cause damage to an organization's assets or processes. Threats can be internal or external, malicious or accidental.

A vulnerability is a flaw that exposes a company to potential threats. Vulnerabilities can be identified using many methods including automated scanning, auditing, penetration testing, vendor security advisories, and application security testing (AST) techniques.

Your analysis should cover not only technical flaws but also physical and process flaws. For example, a data center that does not have physical access control is vulnerable to physical intrusion, while a server that does not have malware protection is vulnerable to cyber threats.

Related content: Read our guide to [vulnerability scanning](#)

3. Analyze Risks and Determine Potential Impact

The next step is to determine how the risk scenarios you identified can impact the organization. In cybersecurity risk assessment, potential risk (the probability that a particular threat can exploit a vulnerability) is based on several factors:

- Discoverability of the security weakness
- Ease of exploitability
- Reproducibility of threats (some threats are one-time and some are continuous)
- Prevalence of the threat in the industry or similar companies
- Historical security incidents

4. Prioritize Risks

A risk matrix can be used to classify each risk scenario. It is important to define a risk tolerance ratio and specify which threat scenarios exceed this threshold. Based on the risk matrix you can determine one of three actions:

- **Avoid**—if the risk is low and it is not worthwhile to mitigate it, it might be best to take no action.

- **Transfer**—if the risk is significant but difficult to address, it is possible to share the risk by transferring responsibility to a third party. This can be done by taking cyber insurance or contracting an outsourced security service.
- **Mitigate**—risks that are significant and within the operational scope of the internal team should be mitigated. You can do this by deploying security controls and other measures to reduce their occurrence and potential impact.

Any risk assessment program must recognize that there is a certain level of residual risk that will be missed, or will not be fully addressed. This must be formally accepted by senior stakeholders as part of an organization's cybersecurity strategy.

5. Document All Risks

It is important to document all identified risk scenarios. This information should be reviewed and updated regularly to provide visibility of the current risk portfolio.

Risk documentation should include details of the risk scenario, date of identification, existing security controls, the risk level, plan for mitigating the risk, current progress, and the residual risk expected after mitigation. Every risk category should have a risk owner—the person or team responsible for keeping the threat to an acceptable level.

Because cybersecurity risk assessment is a large and ongoing effort, it requires time and resources. As new threats emerge and new systems and activities are introduced, the organization must iteratively discover and address these new threats. Hopefully, a robust initial assessment will provide a good basis for subsequent assessments.

Conclusion

In this article, we explained the importance of a security risk assessment and described some of the key organizational systems covered in a risk assessment: physical facilities, servers, networks, data, policies, and third party relationships.

Finally, we presented a 5-step process for conducting risk assessments:

1. **Determine scope**—identify which parts of the organization and which systems need to be assessed.
2. **Threat and vulnerability identification**—scanning the relevant systems to identify vulnerabilities and security weaknesses.
3. **Analyze risks**—determine the business impact of each vulnerability if it were exploited.
4. **Prioritize risks**—identify the order in which vulnerabilities should be handled and the most appropriate strategy for each—avoid, transfer responsibility to a third party, or mitigate.

5. **Document all risks**—create a detailed report of the risks identified and the proposed risk management strategy.

Company

- Leadership
- Careers
- Partners
- Newsroom
- Contact Us

Knowledge

- Center
- Application Security
- Penetration Testing
- Cloud Security
- Hacking
- Cybersecurity
- Attacks
- DevSecOps

Resources

- Blog
- Documentation
- Leaderboard
- Partner Portal
- Resources

Contacted
by a
hacker?